

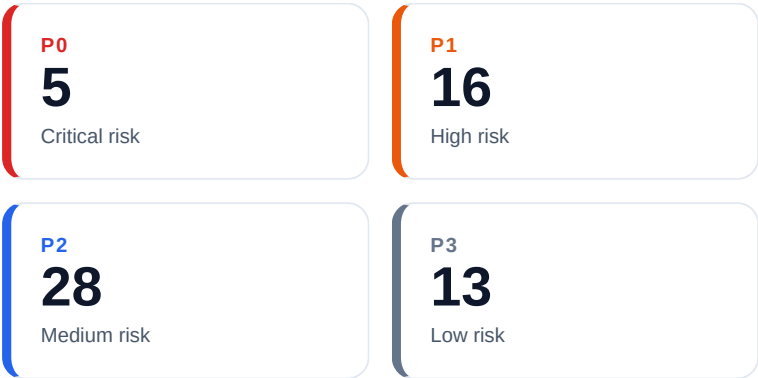
CARE ERP Accounting System Audit

Billing · Payments · Refunds · Cash · Bank · GST · Ledger · Reconciliation

Prepared 2026-07-16 Branch `claude/care-erp-accounting-audit-mcn6la` Scope Read-only · no production behaviour changed

OVERALL VERDICT

Billing + collection system with a fragile single-entry voucher overlay — NOT a genuine accounting system.

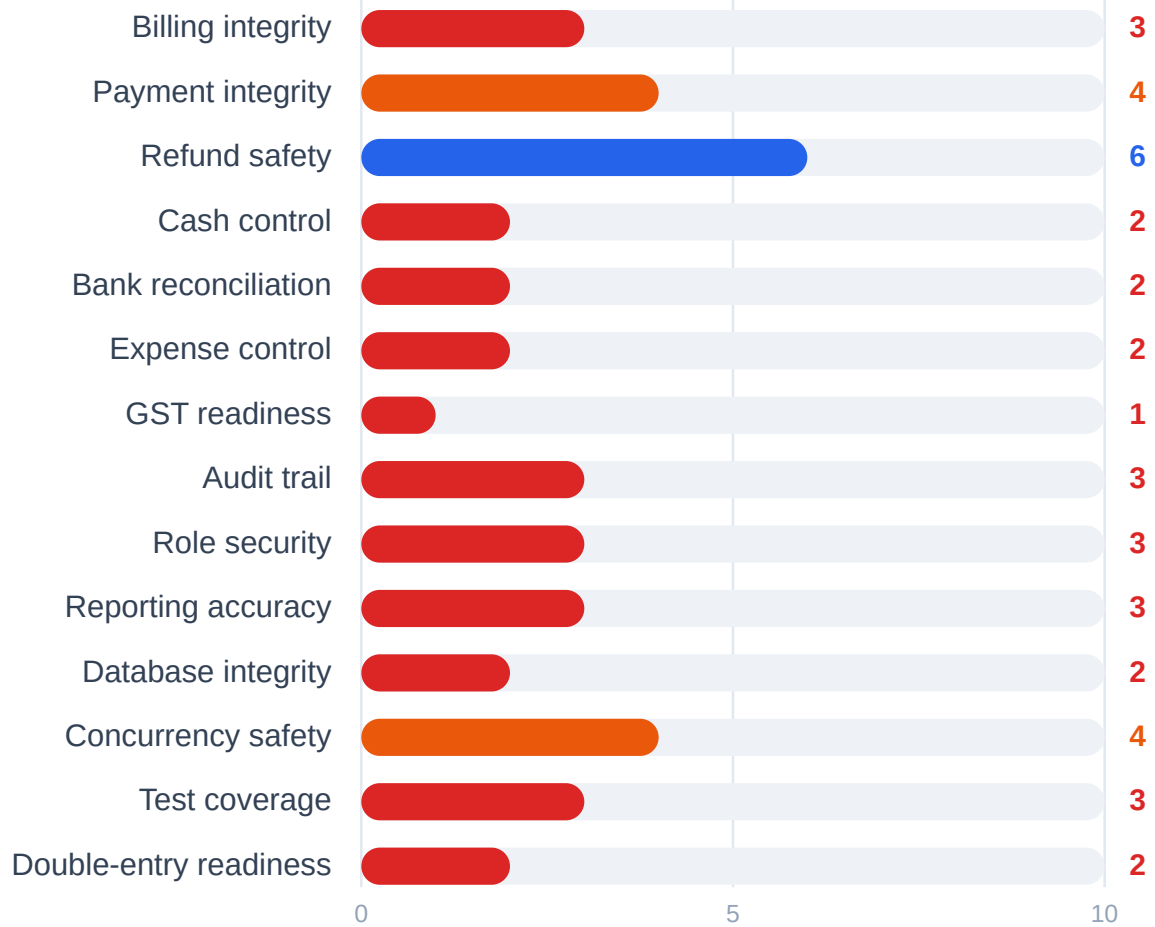


● P0 · Critical 5 ● P1 · High 16 ● P2 · Medium 28
● P3 · Low 13

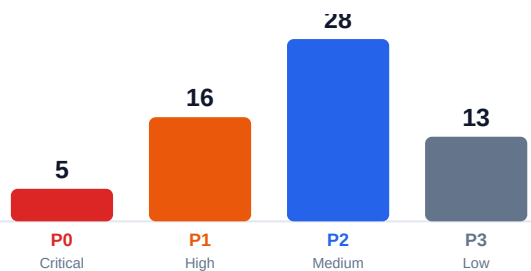
What this means — CARE ERP records and collects money competently, but the numbers it produces are reconstructions from mutable operational tables, not readouts of a posted, balanced ledger. Five P0 defects can destroy or silently corrupt financial records today. A refund handler and mandatory webhook signatures show the team can build controls correctly — the gaps are systemic, not skill.

A Audit scorecard

Each control area scored 0 (absent / broken) to 10 (production-grade). Colour bands: red 0–3, orange 4–5, blue 6–7, green 8–10.



Findings by severity



Reading the score

- **Lowest:** GST readiness (1) — no tax engine, no HSN/SAC, no CGST/SGST split, no credit notes.
- **Cash & bank (2):** drawer arithmetic is wrong and payment-success is confused with bank settlement.
- **Database integrity (2):** the schema enforces essentially no money invariants.
- **Highest:** Refund safety (6) — the one path built with locking, guards and an audit row.

Data-inconsistency status: UNVERIFIED. No database was reachable in the audit sandbox — the read-only `accounting-data-audit.sql` was authored and schema-checked but not executed.

The five P0 findings, each re-confirmed by direct source read during synthesis, followed by the highest-impact P1s.

P0 · Critical — 5

GST-02 / DQ-06

bills.ts:1451

Bill delete rennumbers already-issued invoices and hard-deletes their payments, stranding posted vouchers.

SEC-01

bills.ts:989

Core money-mutations bypass the tamper-evident chain — they write only to a mutable, deletable bill_audits table.

RPT-01

day-close.ts:672

Per-user drawer close subtracts cash expenses twice — cash reconciliation is arithmetically wrong.

DQ-01

0000_dear_forge.sql

Zero CHECK constraints in the financial schema — negative bills, over-refunds and >100% discounts are DB-legal.

DQ-02

zz_schema_reconcile_20260709.sql:142

Reconcile DDL bootstraps bills / payments / vouchers with no unique constraints and no foreign keys.

P1 · High — top 6 of 16

SEC-11

orders.ts:216

Client-trusted customPrice + inline-payment mass assignment → price manipulation.

DQ-04

onlineBookings.ts:19

No global uniqueness for gateway txn identity; webhook vs manual-reconcile paths → duplicate receipts.

SEC-04 / SEC-05

gateway-webhooks.ts:76

Webhook signature does not bind the amount and has no nonce; settlement needs only authentication, not authorization.

DQ-05 / SEC-03

expenses.ts:159

Expense edit double-posts the ledger; expense delete is unaudited and strands vouchers.

GST-03

bills.ts:1364

Finalised invoices editable in place (incl. negative tax) with no credit note → retroactive turnover change.

DQ-03

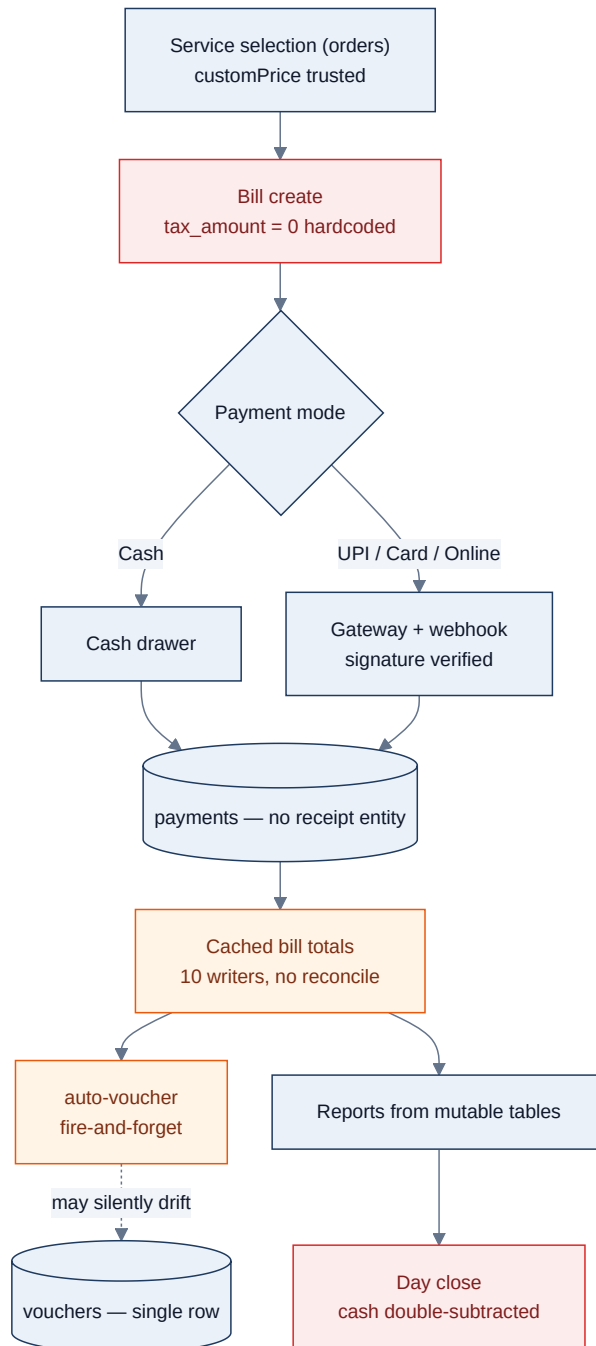
bills.ts:18

Cached bill totals have ten independent writers and no reconciliation to SUM(payments).



Money flow — end to end

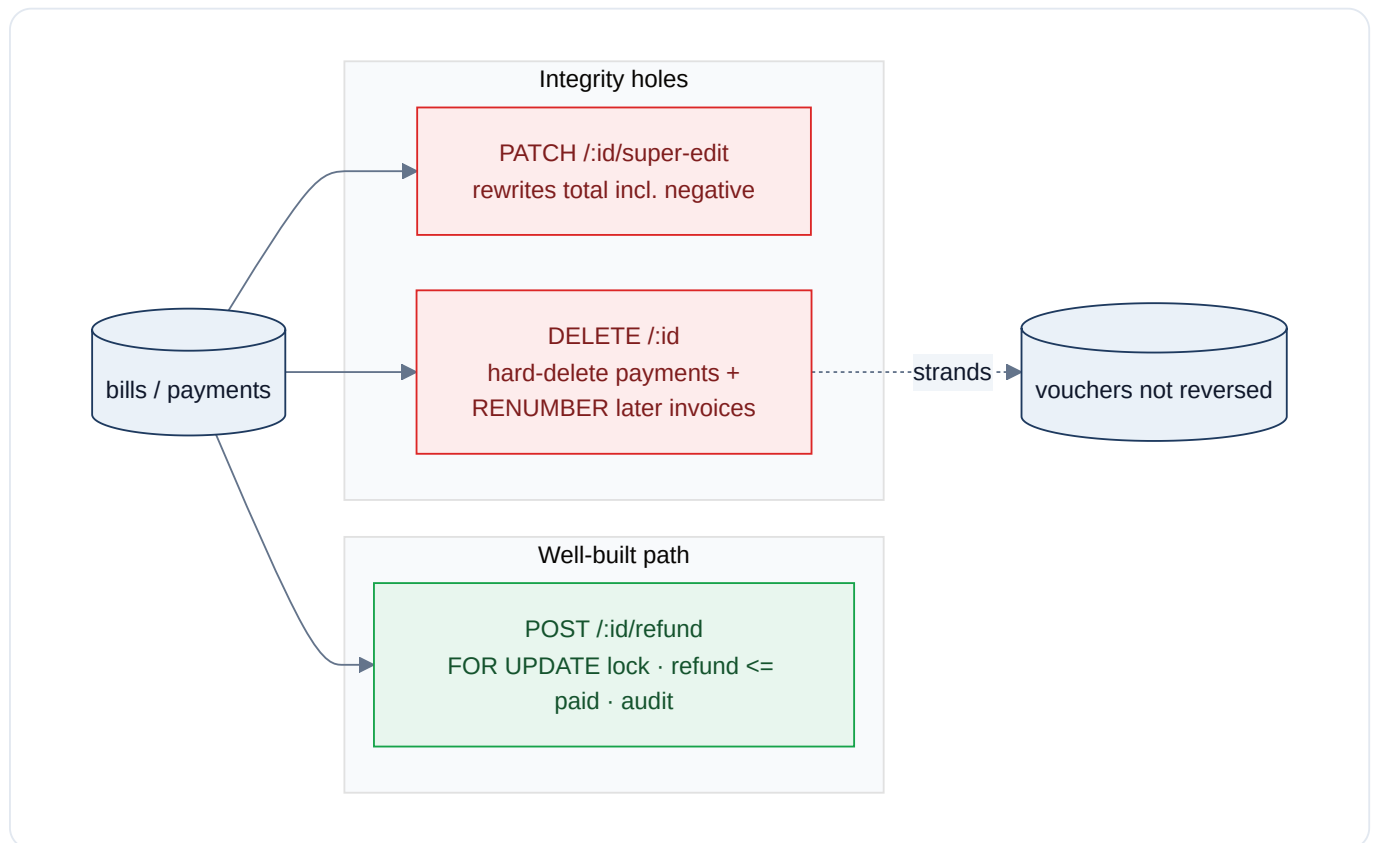
How a rupee moves from service selection to the daily close, with the failure points highlighted.



Red = corrupting defect · Orange = silent-drift risk. Reports are recomputed from mutable tables, so historical totals can change retroactively.

D Bill lifecycle — safe vs. dangerous paths

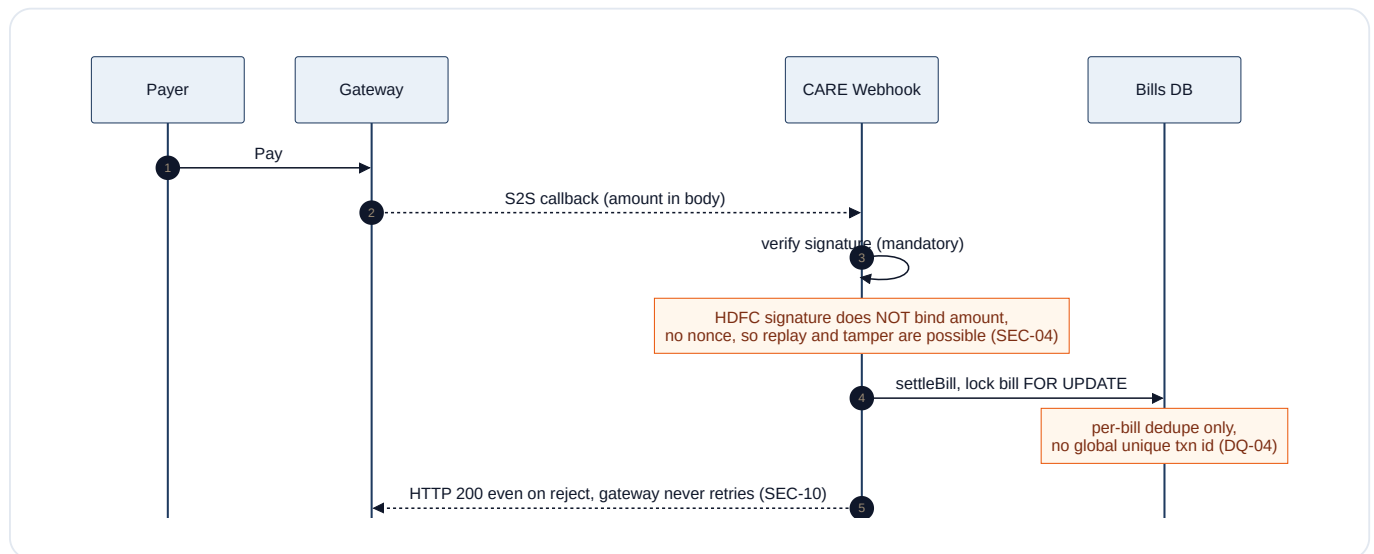
One path is a model of correct control; two others can destroy or rewrite issued financial records.



P0 · GST-02 / DQ-06: DELETE /api/bills/:id hard-deletes the bill and every payment row, then renumbers every later invoice in the month down by one (bills.ts:1502–1524). A number a patient or the GST portal already saw is reassigned to a different bill, settlement evidence is gone, and the posted vouchers still point at the deleted bill — the ledger and the bills table permanently diverge.

E Gateway webhook & settlement

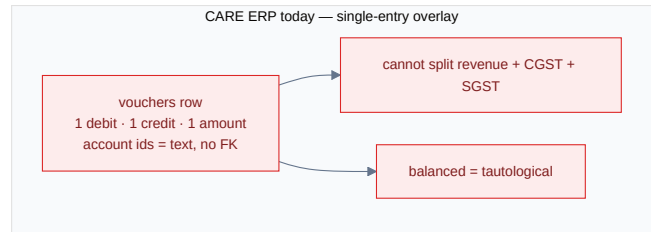
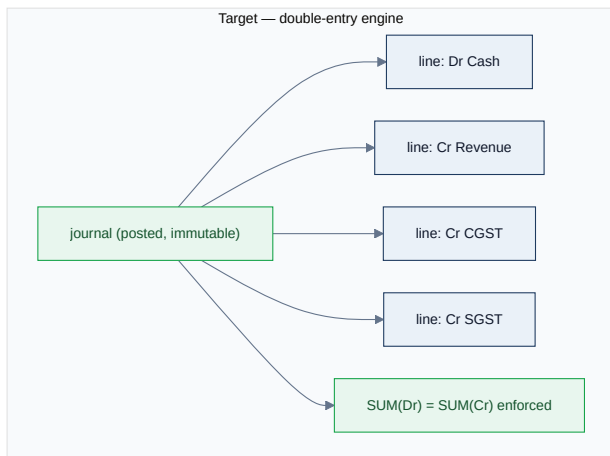
The online-payment callback path. Signature verification is mandatory (good), but three weaknesses remain.



Payment success $\neq$ bank settlement. The system stores no UTR, settlement batch, gateway fee, or bank-credit date. It cannot answer "is this money actually in our account?" — there is no three-way reconciliation.

Idempotency is per-bill only. The webhook keys on `txnID` while manual reconcile passes `bookingRef` — different references for the same payment — so a duplicate receipt can slip across paths (DQ-04).

The voucher is a single row with one debit, one credit and one amount. A real ledger needs balanced multi-line journals.



A single-row voucher cannot break tax out of revenue, so GST is never posted as a ledger liability, and "balanced" is true by construction — not evidence of correctness.



Remediation roadmap & strengths

Phased, backward-compatible where possible. Phase 0 stops irreversible damage; the double-entry core comes only after the integrity foundation is laid.



Phase 0 — ship first (days, not weeks):

- Fix the cash double-subtract (1 line) · replace bill delete-renumber with soft-cancel · freeze in-place edits of finalised bills.
- Add DB CHECK / UNIQUE / FK constraints after quarantining violators · bind amount + nonce into webhook signatures and make them retry-safe.
- Add authorization to settlement · reject client-supplied prices · stop echoing the OTP · audit & gate expense delete, reverse-on-edit.

Existing strengths — build on these

✓ Refund handler

FOR UPDATE row lock, refund ≤ paid guard, total _amount preserved, atomic write + audit row (bills.ts:1140). The template to reuse.

✓ Webhook signatures

Verification is now mandatory — a webhook with a missing hash/secret is rejected (gateway-webhooks.ts:59).

✓ Money type

Amounts stored as PostgreSQL numeric, not float — no storage-level rounding drift.

✓ Concurrency (refund)

Refunds serialised by row locking; no lost update on the refund path.

✓ Audit scaffolding

bill_audits, voucher_audits and an audit_logs hash-chain exist as a foundation to harden.